

AWS SECURITY ASSESSMENT

CONFIDENTIAL

PREPARED BY:

Adaku Okafor
Cybersecurity Analyst

DATE:

26th August 2026

Document Control

Field	Detail
Version	1.0
Audience	NovaPay executive and management stakeholders
Assessment basis	Configuration and validation evidence captured during the evidence window
Post-assessment status	The EC2 instance was terminated after the assessment. Findings describe the assessed state and are not a statement of current exposure.

Report Use and Limitations

This report is based solely on the resources, configurations, and validation observations identified in the assessment record. It does not infer the presence, absence, or condition of services not evidenced in that record. Recommendations are advisory and do not represent completed remediation.

Contents

- Executive Summary
- Scope and Objectives
- Methodology
- Environment and Architecture
- Findings Overview
- Detailed Findings
- Risk Analysis and Matrix
- Positive Controls
- Security Recommendations and Priorities
- Conclusion
- Appendix: Evidence Register

Executive Summary

NovaPay's AWS environment was assessed to identify configuration conditions that could increase exposure to unauthorized access, data disclosure, or loss of recoverability. The assessment identified six findings that require management attention, including publicly reachable SSH access and administrative privileges that exceed documented business needs. The overall risk posture is assessed as **Moderate to High**: a small number of externally exposed and identity-related weaknesses could be combined to materially increase the impact of a credential compromise or service misconfiguration. The environment also demonstrates meaningful safeguards, including audit logging, encryption at rest, and permission enforcement.

Executive Priorities

Priority	Management action	Why it matters
1	Restrict public SSH access	SSH was reachable from the public internet on TCP/22.
2	Enforce MFA for <i>j.developer</i>	The console-enabled user had no MFA protection.
3	Reduce <i>a.admin</i> privileges	AdministratorAccess exceeded the stated role requirement.
4	Enable S3 Block Public Access and <i>customer-backup</i> versioning	These settings reduce accidental exposure and improve recovery resilience.

Important S3 Context

Block Public Access was **OFF** for both identified buckets. This is a configuration weakness because it removes a preventive guardrail. However, actual public readability was not established: neither bucket had a bucket policy, Bucket Owner Enforced was enabled, and both buckets were empty at assessment. SSE-S3 encryption was enabled, so no encryption-at-rest finding is raised.

Scope and Objectives

Scope

- VPC network posture, public/private subnet design, Internet Gateway, public route configuration, and security-group ingress rules.
- Observed external validation using Nmap.
- S3 configuration for **novapay-transaction-logs** and **novapay-customer-backups**.
- IAM authentication and authorization posture for **j.developer** and **a.admin**.
- CloudTrail availability and relevant recorded events.

Objectives

- Identify internet-facing access paths and over-permissive network rules.
- Assess key identity safeguards, including MFA and privilege assignment.
- Assess object-storage preventive controls and recovery-related configuration.
- Confirm evidence of audit logging and authorization enforcement.
- Provide a prioritized, business-oriented security improvement roadmap.

Out of Scope

No conclusions are drawn regarding services or controls not established in the assessment record. In particular, this report does not assess RDS, Lambda, Security Hub, AWS Config, VPC endpoints, or any other unverified resources or services.

Methodology

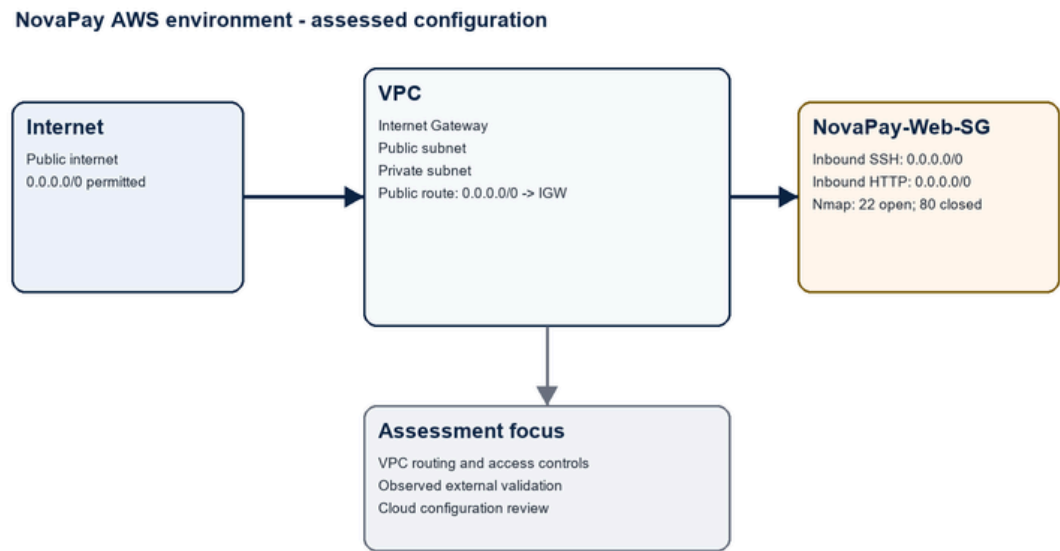
The assessment used an evidence-led configuration review and limited validation approach. Findings were formulated only where configuration or test evidence supported a conclusion.

Method	Application in this assessment
Configuration review	Reviewed VPC routing, security-group rules, S3 settings, IAM group membership and policies, and CloudTrail status/events.
External expose validation	Nmap observation recorded TCP/22 open, TCP/80 closed, and 998 ports filtered.

Authorization validation	Observed j.developer TagUser action denied and recorded by CloudTrail.
Risk evaluation	Considered likelihood of misuse and plausible business impact to assign qualitative severity and prioritization.

Environment and Architecture

The assessed network comprised public and private VPC subnets, an Internet Gateway, and a public route for 0.0.0.0/0 to the Internet Gateway. NovaPay-Web-SG permitted SSH and HTTP from 0.0.0.0/0.



Findings Overview

The assessed network comprised public and private VPC subnets, an Internet Gateway, and a public route for 0.0.0.0/0 to the Internet Gateway. **NovaPay-Web-SG** permitted SSH and HTTP from 0.0.0.0/0.

ID	Finding	Severity	Risk theme
F-01	Internet-exposed SSH access on NovaPay-Web-SG	High	External access
F-02	MFA not enabled for console user <i>j.developer</i>	High	Identity protection
F-03	<i>a.admin</i> holds AdministratorAccess beyond role need	High	Excessive privilege
F-04	S3 Block Public Access disabled on two buckets	Medium	Data exposure guardrail
F-05	Versioning disabled on customer-backups	Medium	Recovery resilience
F-06	Internet-permitted HTTP rule with no confirmed listener	Low	Attack-surface governance

Risk Statement

The principal risk is not that a compromise was demonstrated; rather, it is that internet-reachable administration, incomplete MFA coverage, and broad administrative privilege create avoidable opportunities for unauthorized access and high-impact change. Storage settings and backup-versioning gaps add preventable data-protection risk.

F-01 - Internet-exposed SSH access on NovaPay-Web-SG

Severity	Risk
High	Publicly reachable administrative access increases the likelihood of password, key, or service misconfiguration abuse.

Evidence

NovaPay-Web-SG allowed SSH from 0.0.0.0/0. Nmap showed TCP/22 open. The public VPC route directed 0.0.0.0/0 to the Internet Gateway.

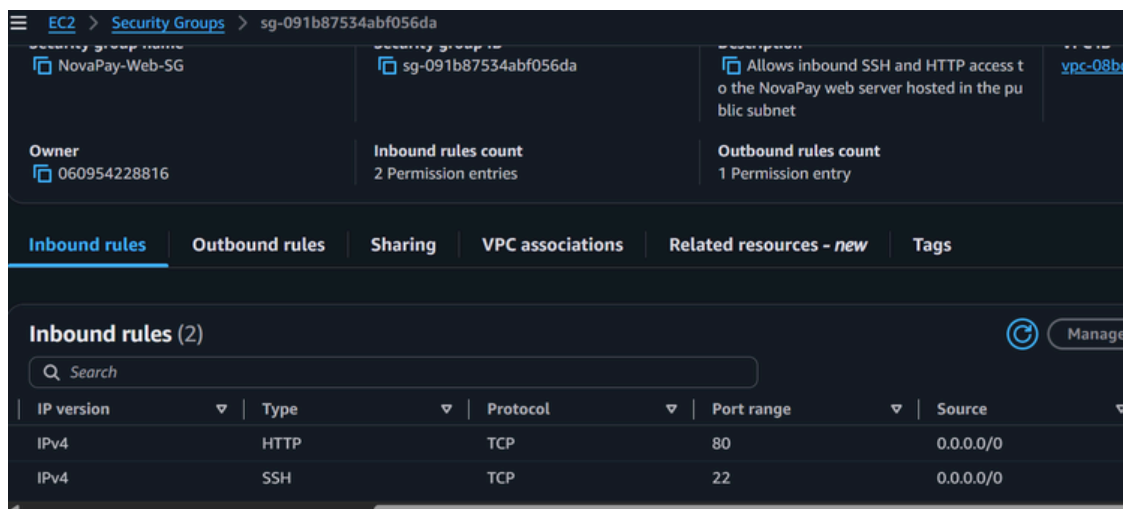


Figure: Security group inbound rules

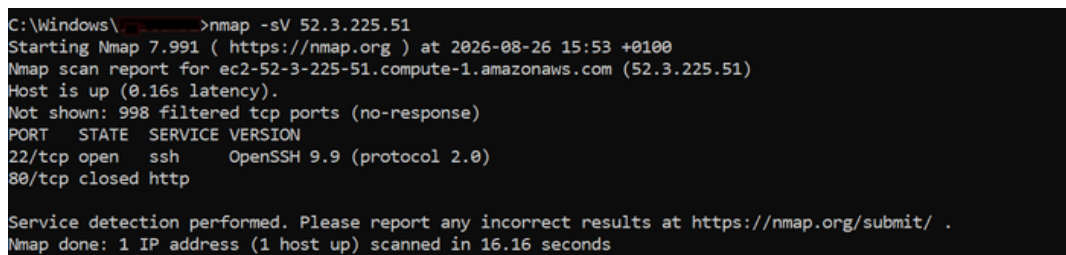


Figure: Nmap result with TCP/22 open

Risk

Publicly reachable administrative access increases the likelihood of password, key, or service misconfiguration abuse.

Recommendation

Limit SSH ingress to approved administrative source ranges or a controlled access path. Remove public SSH where it is not operationally required. Maintain explicit review and approval for any exception.

F-02 - MFA not enabled for console user j.developer

Severity	Risk
High	A console credential without MFA has a lower barrier to account takeover and could enable unauthorized use of the user's assigned permissions

Evidence

j.developer had console access and no MFA. The user belonged to the Developers group, which had ReadOnlyAccess.

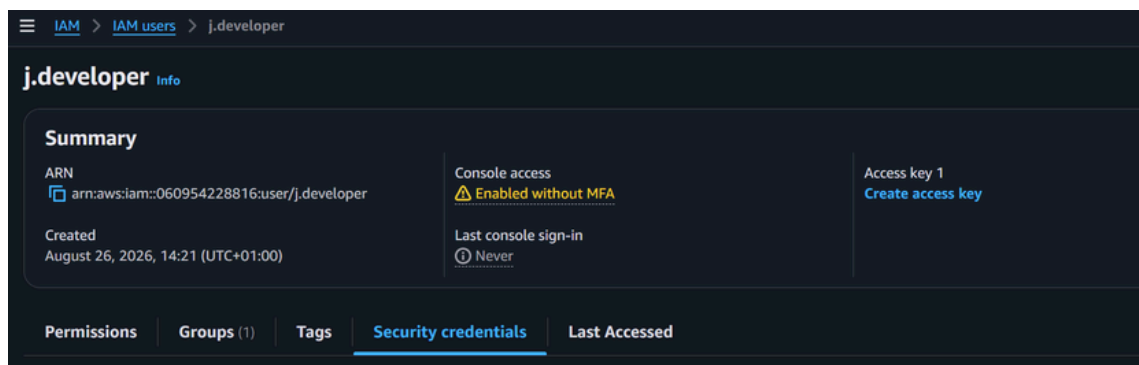


Figure: IAM user security credentials.

Risk

A console credential without MFA has a lower barrier to account takeover and could enable unauthorized use of the user's assigned permissions.

Recommendation

Require MFA for all console-enabled IAM users, beginning with **j.developer**. Establish an enrollment, recovery, and periodic compliance review process.

F-03 - a.admin holds AdministratorAccess beyond role need

Severity	Risk
High	Full administrative capability can enable broad, high-impact changes if the account is misused or compromised.

Evidence

a.admin had MFA and belonged to the Administrators group with AdministratorAccess. The assessment record states the role did not require full AWS administrative privileges.

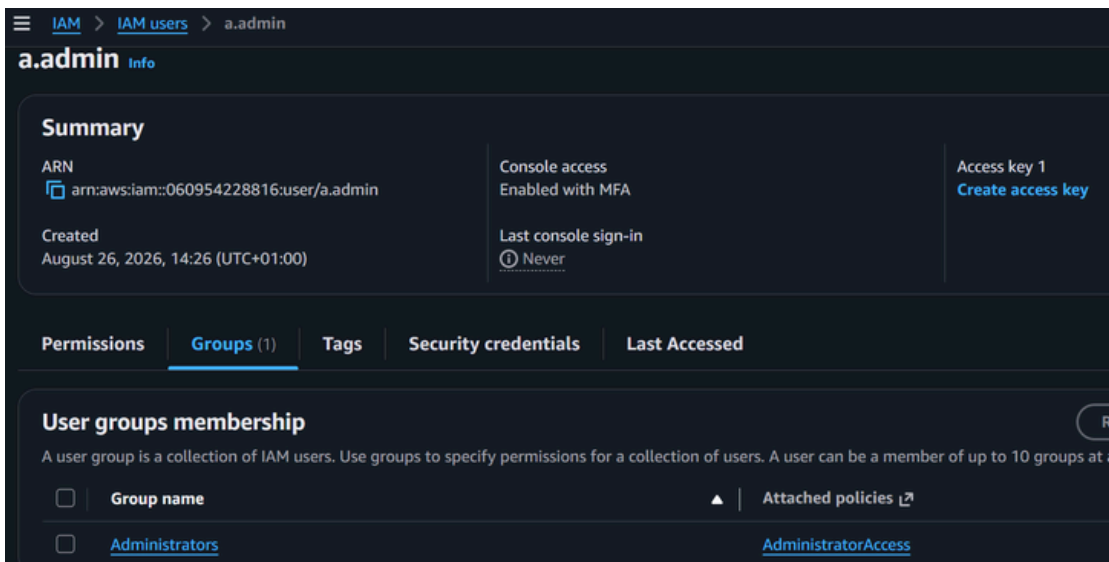


Figure: a.admin group membership and and AdminstratorAccess policy

Risk

Full administrative capability can enable broad, high-impact changes if the account is misused or compromised.

Recommendation

Replace standing AdministratorAccess with role-aligned permissions. Apply least-privilege policies, require elevated access only when justified, and review privileged access regularly.

F-04 - S3 Block Public Access disabled on two buckets

Severity	Risk
Medium	Disabled public-access guardrails can increase the chance of accidental public exposure if future ACL or policy changes are made.

Evidence

Block Public Access was OFF for **novapay-transaction-logs** and **novapay-customer-backups**. Neither bucket had a bucket policy; **Bucket Owner Enforced** was enabled, **SSE-S3** was enabled, and both buckets were empty.

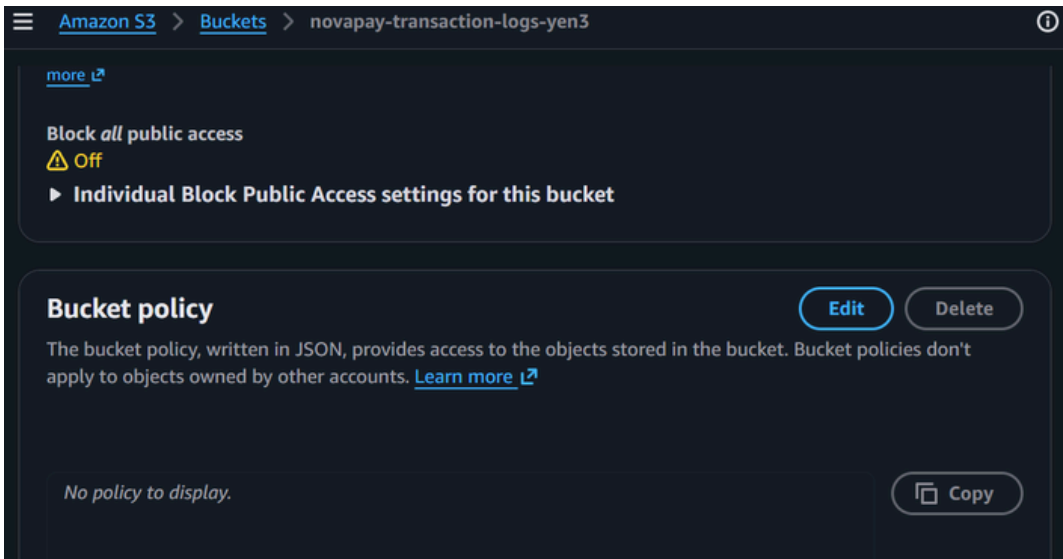


Figure: No Bucket Policy

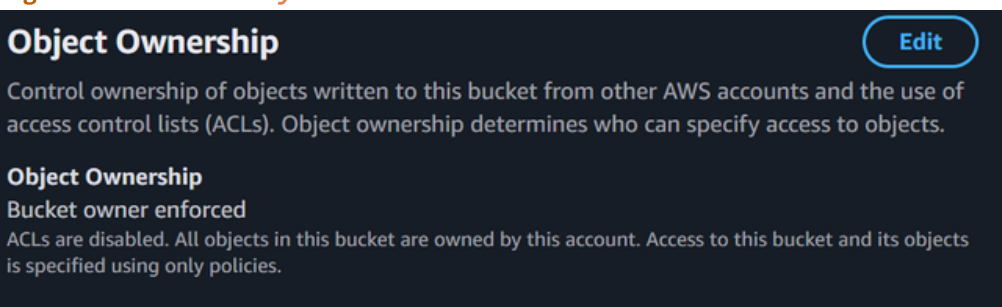


Figure: Bucket Ownership enforced

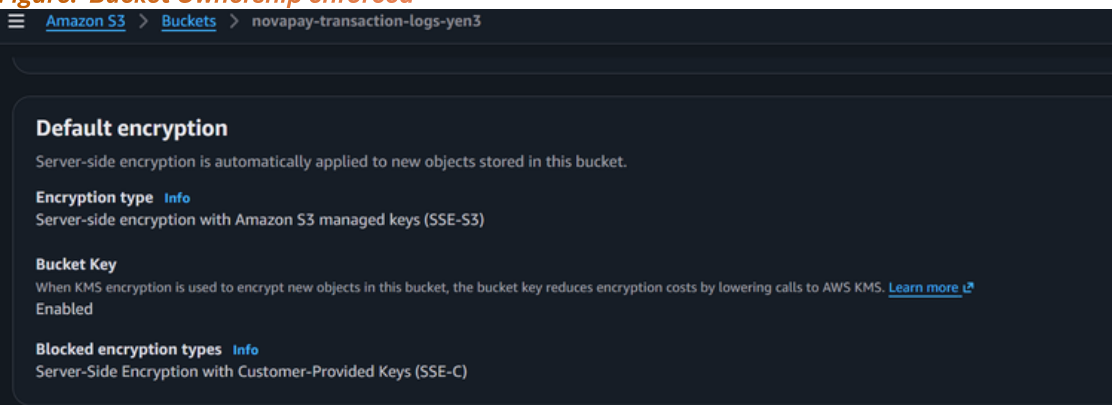


Figure: SSE-S3 encryption

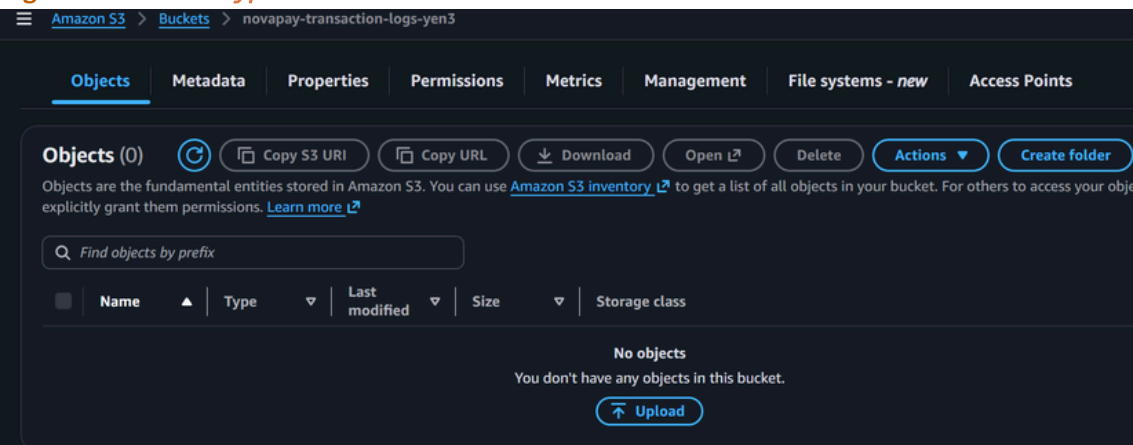


Figure: Empty Bucket state

Risk

Disabled public-access guardrails can increase the chance of accidental public exposure if future ACL or policy changes are made.

Recommendation

Enable and maintain S3 Block Public Access for both buckets unless a formally approved exception is required. Actual public readability was not established from the observed configuration.

F-05 - Versioning disabled on novapay-customer-backups

Severity	Risk
Medium	Without object versioning, accidental deletion or overwrite may be harder to recover from if backup data is stored in the bucket.

Evidence

Versioning was disabled on novapay-customer-backups. The bucket was empty during the assessment.

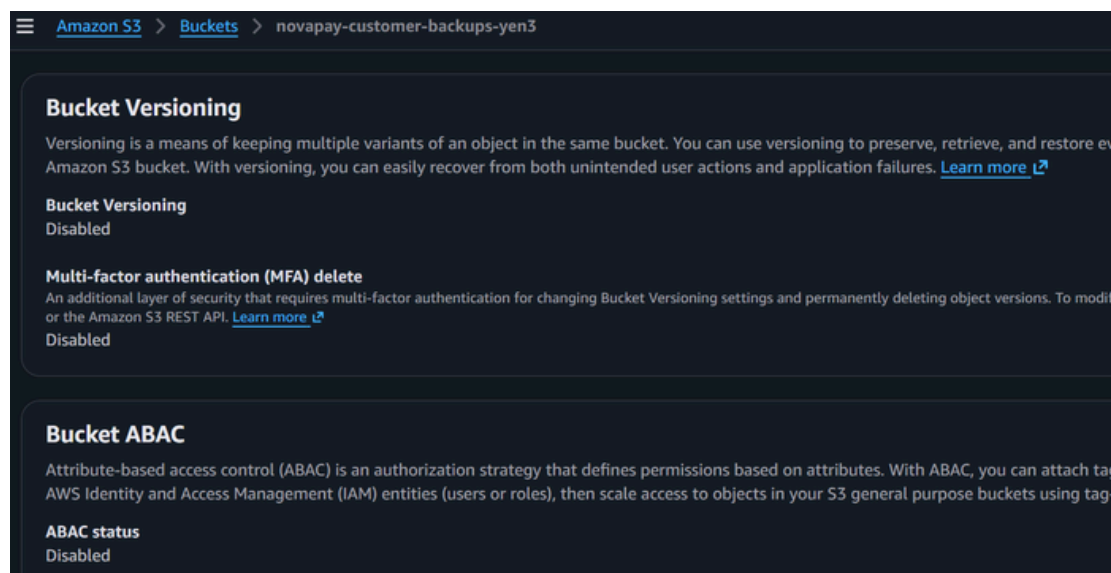


Figure: Versioning disabled for novapay-customer-backups

Risk

Without object versioning, accidental deletion or overwrite may be harder to recover from if backup data is stored in the bucket.

Recommendation

Enable versioning for customer backup data and define retention, recovery, and operational monitoring practices appropriate to the data lifecycle.

F-06 - Internet-permitted HTTP rule with no confirmed listener

Severity	Risk
Low	An open security-group rule is unnecessary exposure when no service is intended to listen on the associated port.

Evidence

NovaPay-Web-SG allowed HTTP from 0.0.0.0/0. Nmap showed TCP/80 closed; therefore, a reachable HTTP service was not established during validation.



Figure: SG showing inbound and outbound permissions

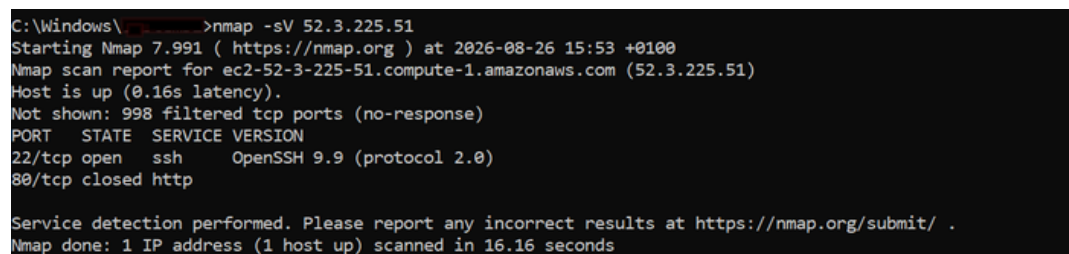


Figure: Nmap output with TCP/80 closed

Risk Analysis and Matrix

Severity reflects a qualitative assessment of likelihood and impact based on the evidence available during the assessment window.

Likelihood/Impact	Low	Moderate	High
High	F-06	F-04, F-05	F-01, F-02, F-03
Moderate	-	-	-
Low	-	-	-

Risk Interpretation

- **F-01, F-02, and F-03** are **High** because public administrative reachability, no MFA for a console user, and unnecessary full administrative access can directly increase exposure and potential impact.
- **F-04 and F-05** are **Medium** because they weaken preventive or recovery controls, while the assessment did not establish current public data access or stored backup data.
- **F-06** is **Low** because the HTTP rule is broad but Nmap showed TCP/80 closed; the concern is governance of an unnecessary rule, not a confirmed listener.

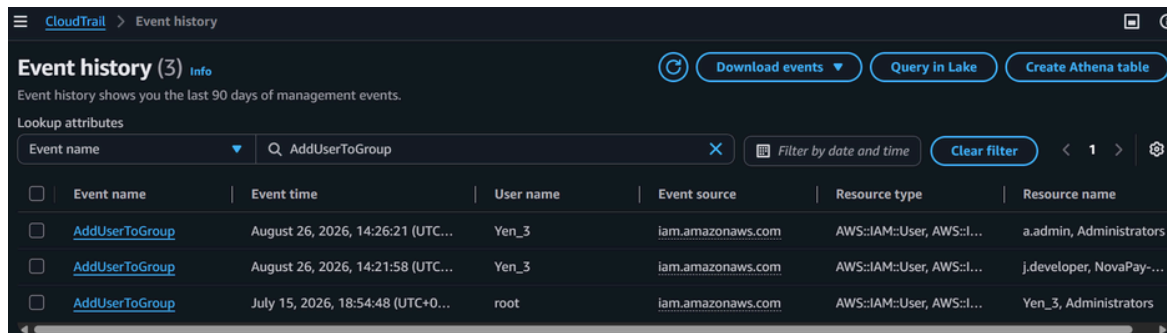
Positive Controls

Control observed	Assessment value
SSE-S3 enabled for both S3 buckets	Encryption at rest was enabled. No encryption-at-rest finding is raised.
Bucket Owner Enforced enabled	Helps centralize object ownership and disables ACL-based public exposure pathways.
Developers group uses ReadOnlyAccess	Provides a least-privilege baseline for j.developer's observed group permissions.

MFA enabled for a.admin	Adds protection to a privileged account.
CloudTrail enabled	Provides management-event auditability.
CloudTrail recorded AddUserToGroup and AccessDenied even	Demonstrates relevant administrative and authorization events were captured.
j.developer TagUser action denied	Shows authorization enforcement operated as expected for the observed attempted action.

Evidence of CloudTrail Logging

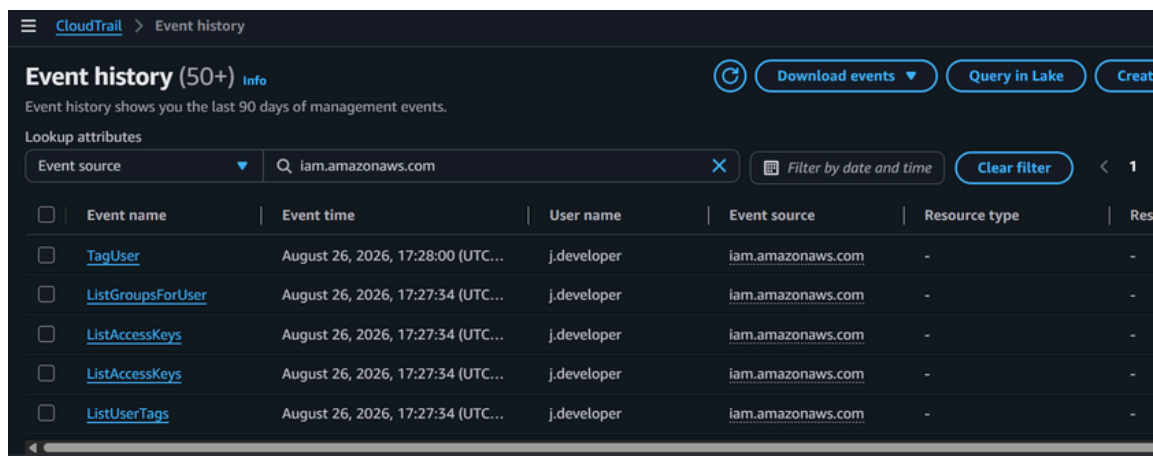
CloudTrail was enabled and captured relevant management events during the assessment, including **AddUserToGroup** event and an AccessDenied event for **j.developer**'s attempted **TagUser** action. This demonstrates that administrative activity and authorization failures were logged for audit review.



The screenshot shows the AWS CloudTrail console 'Event history' page. The filter 'AddUserToGroup' is applied. Three events are listed:

Event name	Event time	User name	Event source	Resource type	Resource name
AddUserToGroup	August 26, 2026, 14:26:21 (UTC...)	Yen_3	iam.amazonaws.com	AWS::IAM::User, AWS::I...	a.admin, Administrators
AddUserToGroup	August 26, 2026, 14:21:58 (UTC...)	Yen_3	iam.amazonaws.com	AWS::IAM::User, AWS::I...	j.developer, NovaPay-...
AddUserToGroup	July 15, 2026, 18:54:48 (UTC+0...)	root	iam.amazonaws.com	AWS::IAM::User, AWS::I...	Yen_3, Administrators

Figure: CloudTrail event history logged



The screenshot shows the AWS CloudTrail console 'Event history' page. The filter 'iam.amazonaws.com' is applied. Five events are listed, all performed by 'j.developer' on 'August 26, 2026, 17:27:34 (UTC...)':

Event name	Event time	User name	Event source	Resource type	Resource name
TagUser	August 26, 2026, 17:28:00 (UTC...)	j.developer	iam.amazonaws.com	-	-
ListGroupsForUser	August 26, 2026, 17:27:34 (UTC...)	j.developer	iam.amazonaws.com	-	-
ListAccessKeys	August 26, 2026, 17:27:34 (UTC...)	j.developer	iam.amazonaws.com	-	-
ListAccessKeys	August 26, 2026, 17:27:34 (UTC...)	j.developer	iam.amazonaws.com	-	-
ListUserTags	August 26, 2026, 17:27:34 (UTC...)	j.developer	iam.amazonaws.com	-	-

Figure: CloudTrail event history logged (2)

```

16 },
17 "eventTime": "2026-08-26T16:28:00Z",
18 "eventSource": "iam.amazonaws.com",
19 "eventName": "TagUser",
20 "awsRegion": "us-east-1",
21 "sourceIPAddress": "154.113.154.36",
22 "userAgent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36",
23 "errorCode": "AccessDenied",
24 "errorMessage": "User: arn:aws:iam::060954228816:user/j.developer is not authorized to perform: iam:TagUser on resource: user j.developer becau
25 "requestParameters": null,
26 "responseElements": null,
27 "requestID": "ca0c770a-a6c8-4109-8e83-1830e9af444e",
28 "eventID": "df61e913-5aad-4af9-a4d8-df55e27cbb8f",
29 "readOnly": false,
30 "eventType": "AwsApiCall",
31 "managementEvent": true,
32 "recipientAccountId": "060954228816",
33 "eventCategory": "Management",
34 "tlsDetails": {
35   "tlsVersion": "TLSv1.3"

```

Security Recommendations and Priorities

Timeframe	Priority recommendations	Outcome sought
Immediate	Restrict SSH exposure; enforce MFA for j.developer; remove or replace unnecessary standing AdministratorAccess for a.admin .	Reduce immediate external and identity-based risk.
Near term	Enable S3 Block Public Access for both buckets; enable versioning for novapay-customer-backups; remove unused public HTTP ingress.	Strengthen preventive data safeguards and recovery capability.
Ongoing	Review security groups, privileged access, MFA compliance, CloudTrail events, and S3 configuration following material changes.	Sustain the improvements and detect drift.

Implementation Governance

Recommendations should be completed through **NovaPay**'s change-management process, with validation evidence retained for management review. No remediation is represented as completed by this report.

Conclusion

The assessment identified a focused set of actionable AWS security weaknesses. The most urgent work is to reduce publicly reachable SSH exposure, ensure MFA coverage for console access, and align a.admin privileges to actual job responsibilities. Strengthening S3 public-access guardrails and backup versioning will improve data-protection resilience.

NovaPay also has a useful foundation: encryption at rest, bucket ownership enforcement, group-level read-only access, MFA for a privileged account, CloudTrail logging, and demonstrated authorization enforcement. Addressing the prioritized findings will help convert these safeguards into a more consistent and defensible cloud security posture